

Security Assessment Report: LoveLetter Locker

Target IP: 10.112.190.133

Assessment Type: Capture The Flag (CTF) / Web Application Security Assessment

Target Platform: TryHackMe — LoveLetter Locker

1. Executive Summary

A security assessment was performed on the target host at 10.112.190.133. The application hosts a web-based messaging platform ("LoveLetter Locker"). During testing, an **Insecure Direct Object Reference (IDOR)** vulnerability was identified in the letter retrieval functionality. This flaw allowed unauthorized access to sensitive records belonging to other users, ultimately leading to a full compromise of confidential letter data and retrieving the target flag (THM{1_c4n_r3ad_4ll_l3tters_w1th_th1s_1d0r}).

2. Reconnaissance & Service Enumeration

An Nmap service scan was executed against the target IP to identify open network ports and running services.

Nmap Scan Results

Plaintext

Nmap scan report for 10.112.190.133

Host is up (0.13s latency).

Not shown: 998 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 256 3b:ec:3f:be:b1:97:94:47:3d:10:9a:a3:98:7d:1b:64 (ECDSA)

|_ 256 55:3c:28:80:8d:d2:ed:4e:c6:a0:56:64:3f:1e:5d:f0 (ED25519)

5000/tcp open http Werkzeug httpd 3.1.5 (Python 3.12.3)

|_ http-title: Home | LoveLetter Locker

|_ http-server-header: Werkzeug/3.1.5 Python/3.12.3

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Key Findings from Scanning:

- **Port 22 (SSH):** Running OpenSSH 9.6p1 on Ubuntu Linux.

- **Port 5000 (HTTP):** Running a Python 3.12.3 web application via the Werkzeug 3.1.5 HTTP engine.

3. Vulnerability Analysis & Exploitation

Web Application Reconnaissance

1. Navigated to the web application hosted at [\[http://10.112.190.133:5000/\]\(http://10.112.190.133:5000/\)](http://10.112.190.133:5000/).
2. Registered a new low-privileged user account and authenticated successfully.
3. Interacted with the core feature: **"Write Letters"**.
4. Upon submitting a test letter and viewing the generated note, the application rendered the content via an explicit database record parameter in the HTTP request URL:
5. Plaintext

`http://10.112.190.133:5000/letter?id=<USER_LETTER_ID>`

6.

IDOR Exploitation

- **Mechanics:** The application failed to validate whether the authenticated user possessed authorization to access the requested `id` parameter.
- **Execution:** Modifying the `id` query parameter directly in the URL from the dynamically assigned value to `1` bypassed client-side restrictions and fetched the letter corresponding to ID `1`.
- **Impact:** The response contained administrative/sensitive letter data, granting unauthorized read access across all user letters stored on the system.

Plaintext

Flag Recovered: `THM{1_c4n_r3ad_4ll_l3tters_w1th_th1s_1d0r}`

4. Vulnerability Breakdown & Remediation

Parameter	Details
Vulnerability Class	Insecure Direct Object Reference (IDOR) / Broken Access Control
OWASP Top 10 Category	A01:2021 – Broken Access Control

CVSS v3.1 Severity	High (7.5 - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
--------------------	--

Recommended Remediation Steps

1. **Implement Server-Side Access Controls:** Ensure the backend validates that the requesting user session owns or is explicitly authorized to view the requested resource ID before returning data.
2. **Use Non-Sequential Identifiers:** Replace sequential integer IDs (e.g., 1, 2, 3) with cryptographically secure Universally Unique Identifiers (UUIDs) to prevent object enumeration.